

DPD modo **on-demand** tiene las siguientes características:

- Es el modo por defecto en equipos Cisco.
- Keepalives DPD son enviados si hay dudas acerca de si el extremo remoto está activo. Cuando se envía tráfico a través del túnel se espera una respuesta, si ésta no se produce entonces los keepalives DPD son enviados.
- Keepalives DPD no son enviados durante los momentos en los que no hay tráfico en el túnel.
- Es posible que un router no descubra un peer muerto hasta que se intente negociar las SA de IKE o IPsec.

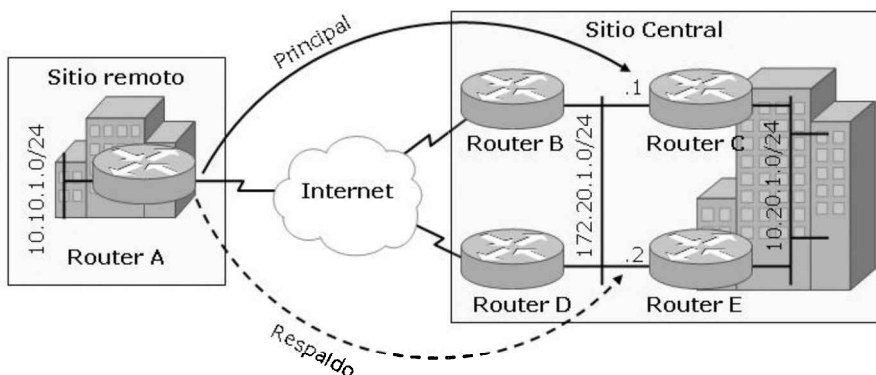
El uso del modo on-demand reduce la sobrecarga introducida en el modo periodic. Pero cabe la posibilidad de que no se use un túnel alternativo inmediatamente después de que un fallo ocurra. Esto no será excesivamente malo cuando no haya datos atravesando el túnel.

En la siguiente sintaxis se muestra cómo configurar DPD en Cisco IOS:

```
crypto isakmp keepalive seconds [retries] [periodic | on-demand]  
set peer ip-address [default]
```

El comando **crypto isakmp keepalive** determina el modo y frecuencia de DPD. Por defecto el modo usado es **on-demand**.

Este comando tiene dos opciones referentes a los temporizadores. La opción **seconds** define la frecuencia de envío de los mensajes DPD en modo **periodic**. La opción **retries** define cuánto tiempo esperar para reenviar mensajes DPD después de que el envío previamente haya fallado.



Router A:

```
crypto isakmp keepalive 10 3
!
crypto ipsec transform-set to-central esp-3des esp-sha-hmac
!
crypto map central-office 10 ipsec-isakmp
set peer 172.20.1.1 default
set peer 172.20.1.2
set transform-set to-central
match address 120
!
access-list 120 permit ip 10.10.1.0 0.0.0.255 10.20.1.0 0.0.0.255
```

En la figura anterior se muestra la configuración del router A para dos peers. El peer principal (172.20.1.1) está configurado utilizando la opción **default**. Éste es el peer empleado inicialmente entre las oficinas remota y central. El peer secundario (172.20.1.2) no es utilizado hasta que DPD determina que el primario ha fallado.

IGP en un túnel GRE sobre IPsec

Al utilizar GRE sobre IPsec es posible ejecutar protocolos de enrutamiento en el túnel. OSPF e IGRP son rápidos a la hora de detectar fallos en los vecinos, de manera que si se emplean túneles de backup GRE sobre IPsec es posible proporcionar la redundancia necesaria. Se debe tener en cuenta que dichos túneles deberían usar caminos diferentes e incluso dispositivos diferentes en el origen y destino para así eliminar puntos únicos de fallo. Este método genera una sobrecarga en el túnel al tener que enviar tráfico de enrutamiento a través del mismo.

HSRP

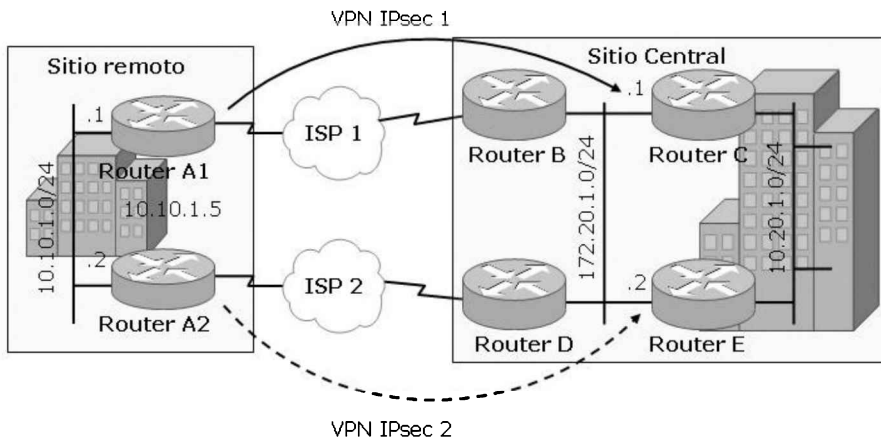
La mayoría de los host están configurados con una sola puerta de enlace, normalmente esta configuración es enviada por algún servidor DHCP. En caso de que dicha puerta de enlace falle los host quedan aislados.

HSRP ofrece la capacidad de usar más de un router como puerta de enlace. Un grupo de routers forman un gateway lógico. Esta dirección IP es utilizada por los host como su puerta de enlace por defecto. Una MAC virtual es asociada con esta IP virtual.

El grupo HSRP controla el tráfico enviado a la IP/MAC lógicas designando uno de los miembros como activo y los demás como standby.

Solamente existe un router por grupo (por puerta de enlace) con el rol de activo, el resto toman el rol de standby. El router activo y el standby se comunican de manera periódica, de esta forma se efectúa la detección de un fallo en estos dispositivos. En caso de que el activo falle el standby toma control del grupo y se encarga de enviar tráfico destinado a la IP virtual del grupo.

En la siguiente muestra vemos una configuración de HSRP en la oficina remota.



Router A1:

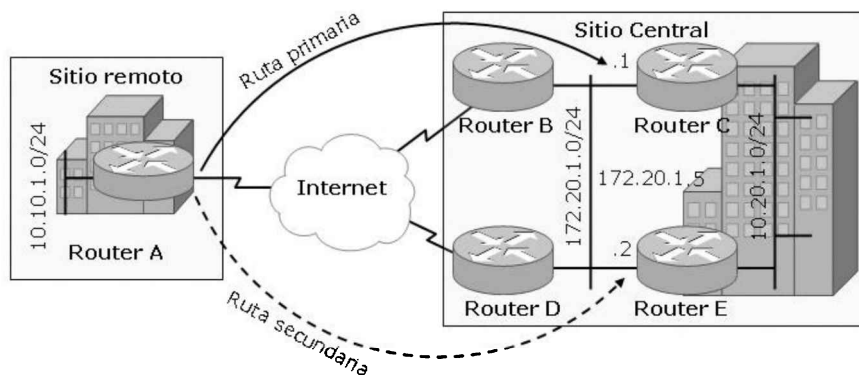
```
interface fastethernet 0/1
ip address 10.10.1.1 255.255.255.0
standby 1 ip 10.1.1.5
standby 1 priority 150
standby 1 preempt
```

Router A2:

```
interface fastethernet 0/1
ip address 10.10.1.2 255.255.255.0
standby 1 ip 10.1.1.5
```

Los host en la oficina remota usan 10.10.1.5 como puerta de enlace predeterminada. Esta es la dirección IP del grupo HSRP entre el router A1 y A2. El router A1 está configurado con una prioridad mayor en HSRP, lo que significa que actuará como activo. El comando **preempt** dice que en caso de fallo y de que pierda el rol de activo, cuando el enlace se recupere podrá recuperar su rol.

En la siguiente figura se muestra una configuración de HSRP en la oficina remota.



Router A:

```
crypto map central-office 10 ipsec-
isakmp
set peer 172.20.1.5
```

Router C:

```
crypto dynamic-map from-remote 10
set transform-set trans1
reverse-route
!
crypto map central-office 10 dynamic
from-remote
!
interface fastethernet 1/0
ip address 172.20.1.1 255.255.255.0
standby 1 ip 172.20.1.5
standby 1 priority 150
standby 1 preempt
standby 1 name vpn-remote
crypto map central-office redundancy
vpn-remote
```

En esta muestra HSRP está configurado entre el router C y el router E para proporcionar redundancia a las conexiones VPN entrantes.

La oficina remota está configurada para terminar la conexión VPN en la IP 172.20.1.5, la cual es la IP virtual del grupo HSRP configurado entre los routers C y E en la oficina central.

En la muestra se observa la configuración para el router C, la configuración del router E será similar. Además se podría crear un grupo diferente entre los routers C y E para proporcionar redundancia a los hosts, de manera similar a la muestra anterior.

La línea de configuración **crypto map central-office redundancy vpn-remote** indica que un grupo HSRP está proporcionando redundancia.

La oficina central está configurada con un crypto map dinámico, el cual permite que cualquier oficina remota pueda iniciar una conexión VPN hacia la oficina central. Esto es especialmente útil cuando las oficinas remotas no tienen una IP fija, como ocurre con muchas conexiones DSL.

Es necesario recordar que si el router C es el activo y falla, la VPN se caerá. La oficina remota reestablecerá la VPN usando la misma IP (la del grupo HSRP 172.20.1.5) que ahora será controlada por el router E. Cuando el router C vuelva a la vida y tome de nuevo el rol de activo, la VPN se volverá a caer y restablecer nuevamente.

Mecanismo IPsec stateful

Este escenario normalmente requiere un juego de dispositivos adicional para que el **failover** pueda ocurrir, también es necesario un intercambio continuo de datos entre los dispositivos para seguir el estado de las VPN IPsec. Esto implica múltiples túneles IPsec VPN activos de manera que el fallo de uno de ellos conmuta el tráfico inmediatamente hacia uno alternativo.

Un entorno **stateful** elimina la necesidad de esperar hasta que el túnel de backup es creado, ya que la información relativa a las SA es mantenida para el túnel de backup, el cual está siempre preparado para automáticamente enviar tráfico ante la posibilidad de que el primario falle. El cambio del primario al de backup sucede de manera transparente para los usuarios y para el peer VPN IPsec.

IP stateful usa dos protocolos:

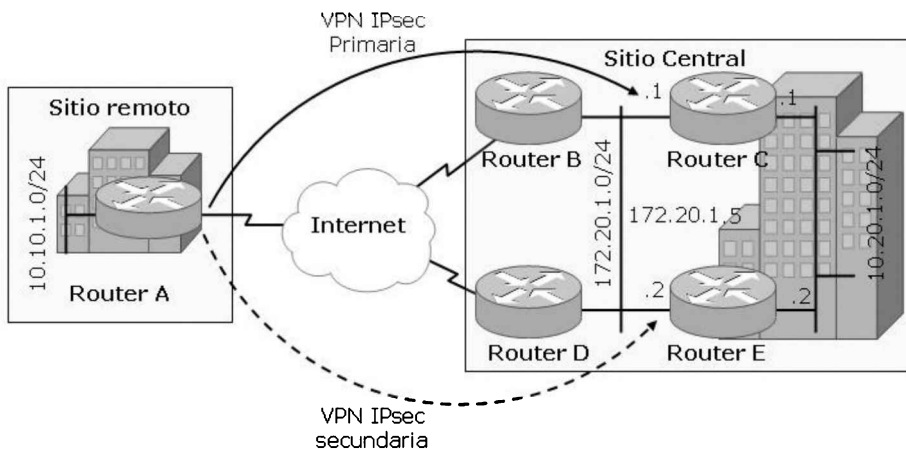
- **HSRP.** Se encarga de monitorizar las interfaces entrantes y salientes. Si alguna de ellas cae el router que está en standby asume el rol de activo.
- **SSO (Stateful Switchover).** Comparte información de las SA de IKE e IPsec entre los routers activo y de backup de manera que ambos tienen la misma información.

Existen ciertas limitaciones que hay que tener en cuenta:

- Ambos dispositivos (activo y standby) han de correr la misma versión de IOS.

- Estos dispositivos han de estar conectados usando puertos LAN, directamente o a través de un switch. Las interfaces WAN no están soportadas.
- Las interfaces entrante y saliente deben estar conectadas usando puertos LAN.
- Solamente es soportado el failover de dispositivo a dispositivo y no entre módulos.
- No se soporta balanceo de carga, sólo un dispositivo puede estar activo a la vez.
- Los mensajes de keepalive de IKE no están soportados. Los mensajes DPD sí están soportados.
- Stateful failover de Layer 2 Tunneling Protocol (L2TP) no esta soportado.
- Los temporizadores **idle** de IPsec no están soportados.

Debido a que IPsec stateful failover utiliza HSRP y SSO ambos protocolos han de estar debidamente configurados. En la siguiente figura se muestra la configuración necesaria en la oficina central.



Router C:

```
crypto dynamic-map from-remote 10
set transform-set trans1
reverse-route
!
crypto map central-office 10 ipsec-isakmp dynamic from-remote
!
interface fastethernet 1/0
ip address 172.20.1.1 255.255.255.0
standby 1 ip 172.20.1.5
standby 1 priority 150
standby 1 preempt
standby 1 name vpn-remote
crypto map central-office redundancy vpn-remote stateful
!
redundancy inter-device
scheme standby vpn-remote
!
ipc zone default
association 1
protocol sctp
local-port 12321
local-ip 10.20.1.1
retransmit-timeout 300 10000
path-retransmit 10
assoc-retransmit 20
remote-port 12321
remote-ip 10.20.1.2
```

En la figura se muestra como la configuración del **crypto map** y de la interfaz son similares a las de la figura anterior, la diferencia es la adición del término **stateful** al crypto map en la interfaz. Esto permite el uso de SSO para llevar a cabo **stateful failover**. La configuración de HSRP es la misma que antes. La configuración en el router E sería similar a la del router C.

El comando **redundancy interdevice** configura redundancia y entra en el modo de **configuration inter-device**. Actualmente el único esquema soportado es standby. Hay que resaltar que el nombre del **standby**, **vpn-remote**, debe coincidir con el nombre del grupo standby definido con el crypto map en la interfaz.

Los siguientes comandos configuran el **IPC** (Inter-device Communication Protocol) entre las dos puertas de enlace. El comando **ipc zone** default inicia el enlace de comunicación entre los routers activo y standby. El subcomando **association** crea una asociación entre los routers activo y standby y utiliza **SCTP** (Stream Control Transmission Protocol) como protocolo de transporte.

En SCTP los puertos SCTP locales y remotos son definidos así como las direcciones IP. El puerto local configurado en este router ha de ser el puerto remoto

configurado en el router peer. Las direcciones IP han de ser las direcciones físicas de las interfaces y no virtuales.

El comando **path-retransmit** define el número de intentos de SCTP antes de dar por fallido el intento de crear la sesión. El comando **retransmission timeout** define el tiempo máximo que SCTP espera antes de retransmitir datos.

IPsec VPN de respaldo para redes WAN

Hasta ahora se han visto soluciones para recuperar conectividad para el caso de un fallo en la VPN. Sin embargo existe una alternativa un poco diferente en este uso de las VPN. La idea es asumir que existe una conexión WAN y que se utilizará una VPN a través de Internet como backup en caso de que la interfaz WAN se caiga.

Existen dos maneras de usar esta solución:

- La primera es emplear el mismo protocolo de enrutamiento en ambos enlaces, configurando una métrica peor en la interfaz de la VPN, de manera que si la interfaz WAN se cae la tabla de enrutamiento pueda converger y enrutar tráfico a través de la VPN.
- La segunda opción es utilizar rutas estáticas flotantes para el enrutamiento a través de la VPN. Dichas rutas tienen peor Distancia Administrativa que la del protocolo de enrutamiento utilizado en la interfaz WAN, por lo tanto sólo se instalarán en la tabla de rutas una vez que se haya perdido la ruta a través del enlace WAN.

La idea en ambos casos es usar la conexión WAN normal para enrutar tráfico, pero en caso de que ésta falle poder enviar dicho tráfico de manera temporal hasta que ésta se recupere mediante la VPN a través de Internet.

CISCO EASY VPN

INTRODUCCIÓN A CISCO EASY

Cisco Easy VPN simplifica el despliegue de VPN en oficinas remotas y para teletrabajadores, permitiendo gestionar de una manera centralizada dichos clientes.

Cisco Easy VPN está compuesto por dos componentes, Server y Remote.

Cisco Easy VPN Remote

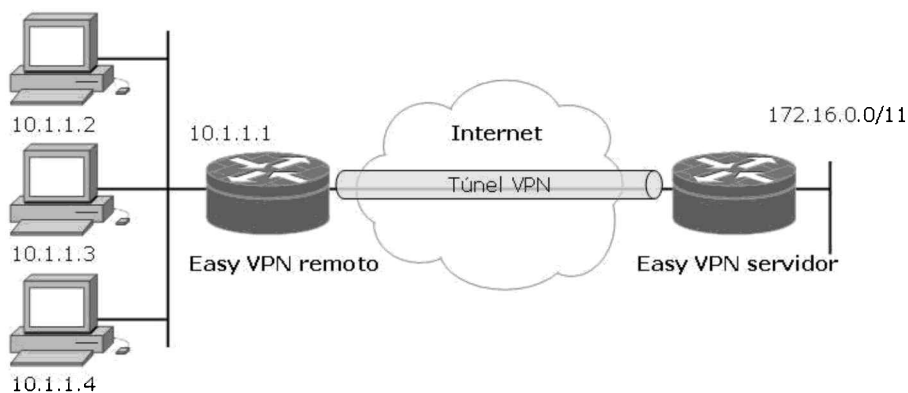
Cisco Easy VPN Remote permite a los dispositivos como los routers con IOS, firewalls PIX, concentradores VPN3000, actuar como clientes VPN remotos, recibiendo políticas de seguridad desde un VPN Server y minimizando así la necesidad de aplicar configuraciones de forma manual. Easy VPN Remote proporciona gestión descentralizada y automática de las siguientes tareas:

- Parámetros de negociación del túnel.
- Establecimiento del túnel.
- Creación automática de NAT y PAT y de cualquier ACL necesaria.
- Autenticación del usuario.
- Gestión de las claves de seguridad para encriptar y desencriptar.

Cisco Easy VPN Remote soporta tres modos de operación:

- **Client**, especifica qué NAT o PAT se utilizará de manera que los dispositivos remotos no están en el mismo rango de direccionamiento que el Server.
- **Network Extensión**, especifica que los dispositivos remotos usan direccionamiento totalmente enrutable a través del túnel, formando una sola red lógica.
- **Network Extension Plus**, es exactamente igual al modo anterior pero con la capacidad añadida de pedir una dirección IP de forma automática y asignar la a una interfaz loopback.

El modo cliente está ampliamente extendido y se muestra en la siguiente figura.



Como muestra la imagen los host utilizan direccionamiento de la RFC 1918 el cual no es enrutable en Internet. Para enrutar este tráfico se emplea PAT. Con la VPN configurada en modo **client** la información de enrutamiento pasa entre el sitio central y el sitio remoto.

Cisco Easy VPN Server

Hay ciertos requerimientos de hardware y software que se han de cumplir para implementar Easy VPN.

- Cisco Routers 831, 836, 837, 851, 857, 871, 876, 877, 878, serie 1700, serie 2600, serie 3600, serie 7100 VPN, serie 7200, serie 7500. Cisco IOS 12.2(8)T o superior.

- Cisco PIX serie 500. PIX OS 6.2 o superior.
- Cisco Concentrador VPN serie 3000. Software 3.11 o superior.

Adicionalmente es una necesidad por parte de los Easy VPN Servers emplear políticas ISAKMP con DH versión 2. Esto es necesario porque el protocolo **Cisco Unity** solamente soporta políticas ISAKMP utilizando DH versión 2. El protocolo Cisco Unity se refiere a la metodología que los clientes VPN usan para determinar el orden de eventos cuando intentan establecer una conexión VPN con el servidor.

Un cliente **Unity** primero ha de identificarse por grupo y en caso de que XAUTH (IKE extended authentication) esté habilitado también por usuario. Cisco Easy VPN Server no se puede configurar con los grupos 1 o 5 de ISAKMP cuando se usa con Easy VPN Client.

Para asegurarse de que el túnel es plenamente seguro, Cisco Easy VPN Remote requiere a la vez autenticación y encriptación en los transforms sets.

El protocolo Cisco Unity no soporta AH pero sí ESP.

Hay veces en las que una conexión VPN se utiliza como solución de backup del enlace principal, por lo tanto hay que tener en cuenta que Easy VPN no se puede utilizar como backup basándose en el estado del enlace de la interfaz principal (Up/Down).

Por último mencionar que no es posible utilizar NAT si split tunneling está habilitado, debido a la posibilidad de solapamiento de direcciones IP.

ESTABLECIMIENTO DE LA CONEXIÓN EASY VPN

Cisco Easy VPN Remote realiza un proceso de dos fases para la autenticación cliente/servidor:

- **Fase 1: autenticación a nivel de grupo.** Durante esta fase pueden utilizarse dos tipos de autenticación, claves precompartidas o certificados digitales.
- **Fase 2: autenticación extendida o Xauth.** El extremo remoto envía un usuario y contraseña al sitio central, de manera que el router remoto queda autenticado. Xauth es opcional pero altamente recomendable.

Los siguientes pasos representan la secuencia de conexión de un Cisco Easy VPN Client a un Cisco Easy VPN Server.

1. VPN Client inicia IKE Fase 1.
2. VPN Client establece una SA ISAKMP.
3. Easy VPN Server acepta la SA propuesta.
4. Easy VPN Server comienza la autenticación de usuario.
5. Comienza el modo configuración.
6. Comienza el proceso **RRI** (Reverse Route Inject).
7. IPsec modo quick completa la conexión.

IKE Fase 1

Durante este paso inicial el proceso IKE es iniciado. Hay dos posibles formas de autenticación durante este proceso:

- Clave precompartida. El cliente VPN inicia el modo agresivo. Cada extremo es consciente de la clave del otro. Un nombre de grupo ha de ser configurado también, para identificar el perfil del grupo asociado con el cliente.
- Certificados digitales. El cliente VPN inicia el modo main o principal. Los certificados digitales usan firmas RSA en dispositivos Cisco Easy VPN Remote. Cuando se utilizan certificados digitales una unidad organizativa con nombre único es usada para identificar el perfil de grupo usado.

Cuando se utiliza el modo agresivo la identidad del dispositivo IOS VPN ha de ser cambiada con el comando **crypto isakmp identity hostname**. Dicho comando permite el empleo de una dirección IP o de un nombre, tal y como se muestra en las siguientes sintaxis, las dos opciones tienen idénticos resultados:

```
Router(config)#crypto isakmp identity address
Router(config)#crypto isakmp key sharedkeystring address
192.168.1.61
Router(config)#crypto isakmp identity hostname
Router(config)#crypto isakmp key sharedkeystring hostname
Router.remoto.CCNP
Router(config)#ip host Router.remoto.CCNP 192.168.1.61
```

Estableciendo una SA ISAKMP

Cuando el cliente VPN quiere establecer una SA entre peers envía una serie de propuestas al Easy VPN Server. Ya se ha mencionado anteriormente que Easy VPN sólo soporta ISAKMP DH versión 2. Además del grupo DH se envían varias alternativas de encriptación, hash, autenticación y longitud del grupo DH.

Aceptación de la propuesta SA

Una política ISAKMP puede estar compuesta de varias propuestas, la primera de dichas propuestas aceptada será la que encaje con la primera configurada en el VPN Server. Debido a este procedimiento las políticas más seguras deberían estar configuradas primero. Una vez aceptada una propuesta el dispositivo es autenticado y comenzará la autenticación de usuario.

Autenticación de usuario

Si el VPN Server está configurado para XAUTH, el VPN Client requerirá necesariamente un usuario y contraseña para que pueda enviarlo al VPN Server. Dicha combinación de usuario y contraseña puede estar guardada localmente, en un servidor TACACS, RADIUS, etc.

Modo configuración

El cliente VPN solicita al VPN Server aquellos parámetros que tenga configurados y que necesite enviarle para completar la configuración. El único parámetro obligatorio es el direccionamiento IP, los demás, tales como información DNS o Split tunneling son opcionales.

RRI

RRI (Reverse Route Injection) es el proceso de inyectar en el IGP una ruta estática, la cual apunta hacia la red de destino. Esto es útil cuando se utiliza un direccionamiento IP estático por cada cliente y no un almacén de direcciones por VPN.

RRI ha de ser habilitado en los crypto maps dinámicos cuando existen múltiples VPN Servers.

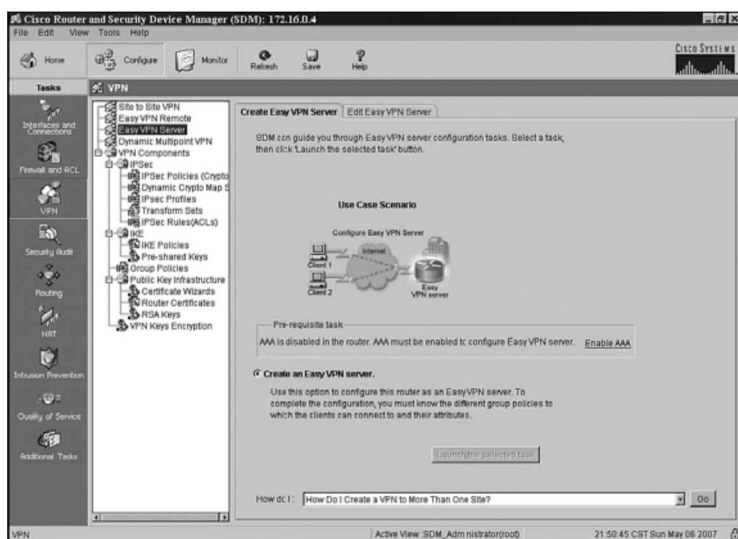
Modo IPsec rápido

El modo quick o rápido de IPsec negocia el establecimiento de una SA para IPsec. Éste es el paso final, una vez que la SA es creada, la conexión se completa y estará activa.

CONFIGURACIÓN DE EASY VPN SERVER

Para configurar Easy VPN Server es posible utilizar el modo CLI o Cisco SDM.

A continuación se detalla la configuración a través de SDM. La siguiente figura muestra el punto de partida para la configuración. Por todo lo visto anteriormente ya se debería estar lo suficientemente familiarizado con SDM como para llegar a ella sin problemas.



Dentro de las opciones disponibles seleccionar **Easy VPN Server**. El asistente presenta un número de tareas a realizar:

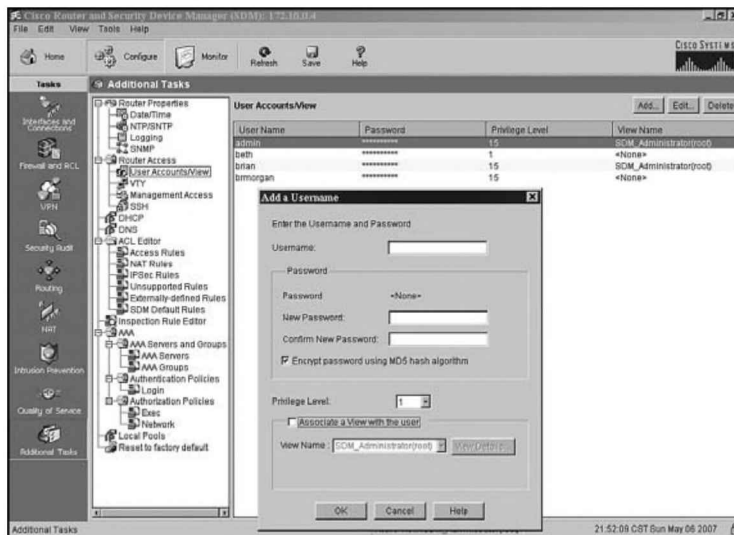
- Selección de la interfaz de terminación de IPsec.
- Configuración de las políticas IKE.
- Configuración de la metodología de búsqueda de las políticas de grupo.

- Autenticación del usuario.
- Configuración de las políticas de grupo locales.
- Configuración de los transform sets de IPsec.

Antes de realizar la configuración del Easy VPN Server todos los demás servicios tales como AAA, direccionamiento IP, enrutamiento, autoridades certificadoras, DNS, NTP, etc., han de estar funcionando.

Configuración de usuario

La configuración de usuarios en SDM se realiza usando la opción **additional task** en el menú de la izquierda, como muestra la siguiente figura.

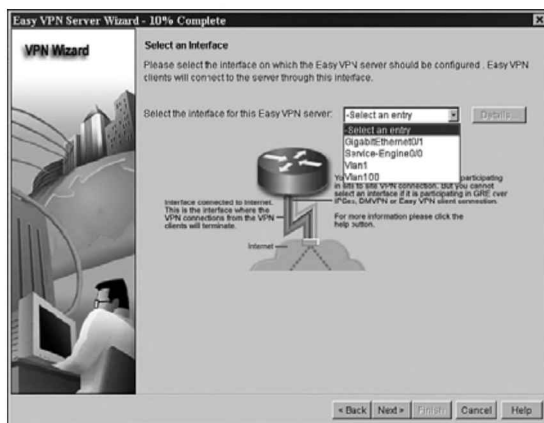


Para llegar a este punto es necesario seguir esta secuencia: **Additional Rasks > Router Access > User Accounts / View > Add.**

Asistente Easy VPN Server

Al pulsar el botón **Launch the Selected Task** se carga el asistente. La pantalla inicial es un resumen de las tareas a realizar en la que es posible configurar AAA en caso de no haberlo realizado previamente.

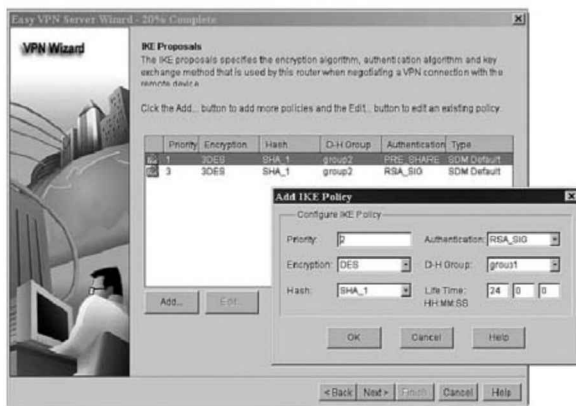
Al pulsar **Next** aparecerá la pantalla de selección de la interfaz que se utilizará con Easy VPN. La figura que sigue muestra dicha pantalla.



Una vez seleccionada la interfaz pulsar **Next** para pasar a la ventana de selección de las propuestas de IKE. Los parámetros a configurar son:

- Prioridad del **proposal** de IKE.
- Grupo de Diffie-Hellman (1, 2 o 5).
- Algoritmo de encriptación (DES, 3DES, AES o SEAL).
- HMAC (SHA-1 o md5).
- Tiempo de vida de IKE.

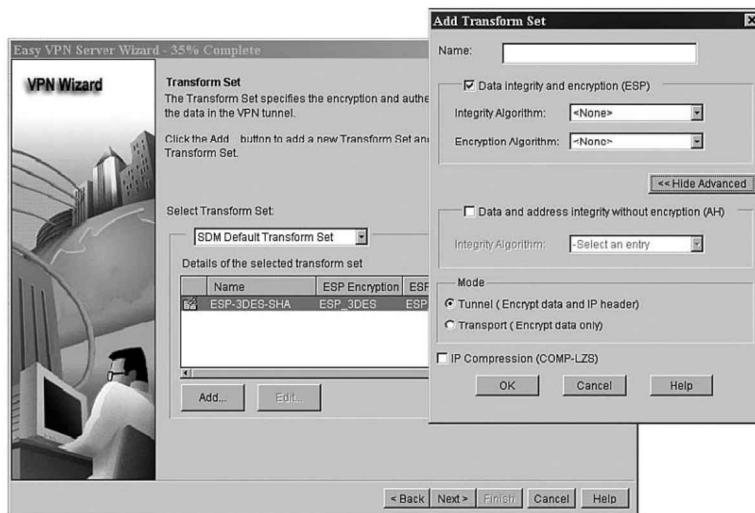
La siguiente figura muestra la pantalla donde las nuevas propuestas son añadidas a la lista existente de **proposals**.



Para configurar los transform sets pulsar **Next**. Como ocurre con IKE ya existe uno configurado por defecto. Los parámetros a configurar son:

- Nombre del transform set.
- Algoritmo de encriptación.
- HMAC.
- Compresión (opcional).
- Modo de operación (transporte o túnel).

La siguiente figura muestra la pantalla donde el nuevo transform set es añadido a la lista existente de transform sets.



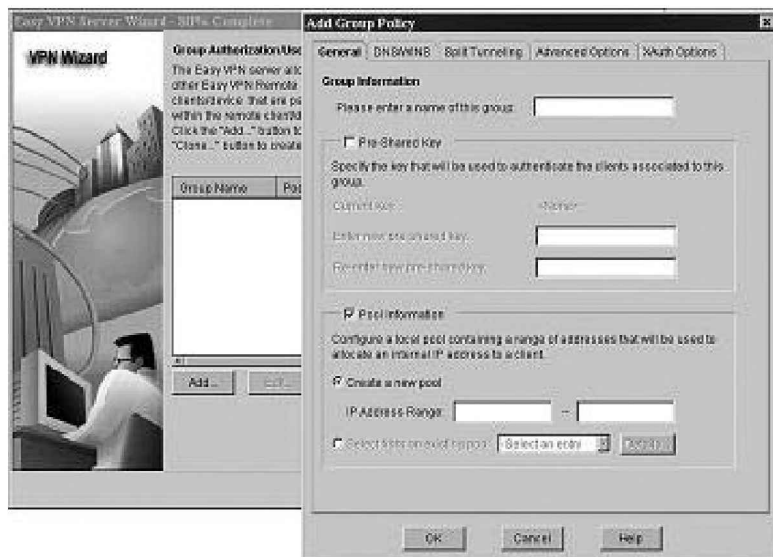
El siguiente paso es configurar las políticas de grupo y autorización del mismo, las que serán utilizadas por grupos de clientes que empleen la misma información para autenticarse y que tengan la misma configuración.

Es posible configurarlo en el Easy VPN Server, en un servidor RADIUS o TACACS externo o ambos. Las líneas de configuración de AAA definirán qué método utilizar en relación a un orden.

El siguiente paso en la configuración es el método para XAUTH. La siguiente figura muestra la información relativa.

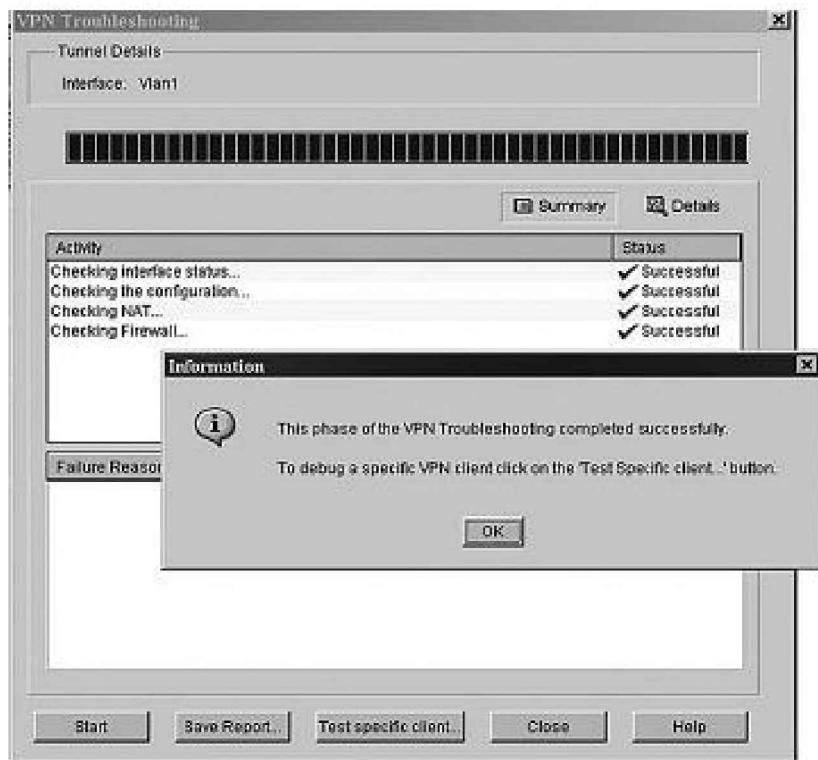


Pulsar **Next** para pasar a la página **Group Authorization/User Group Policies**. Aquí es posible configurar grupos de usuarios remotos que utilizarán VPN Client o VPN Remote. Los atributos configurados en esta página (se ven en las pestañas superiores de la figura) son transferidos al cliente de manera acorde a su pertenencia a grupo.



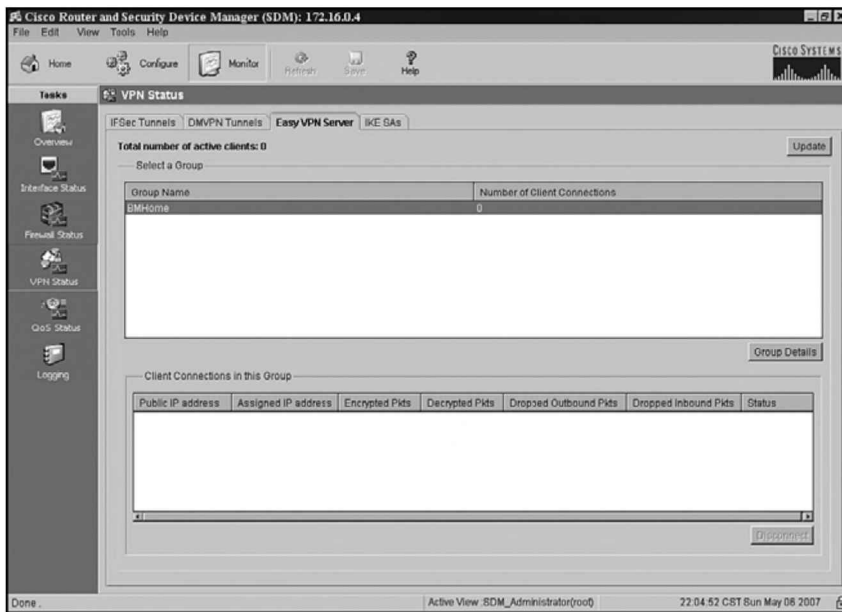
Una vez introducida la información se accede a la pantalla de resumen de la configuración del VPN Server antes de que sea cargada en el router.

Existe la opción de hacer un test de conectividad, como muestra la siguiente figura.



MONITORIZACIÓN DE EASY VPN SERVER

En la parte superior de la página principal del SDM está la opción **Monitor**, como se ve en la figura, donde cada grupo VPN Server puede ser monitorizado individualmente.



Desde la CLI los comandos **show crypto isakmp sa** y **show crypto ipsec sa** resultan útiles, los siguientes son un ejemplo de ellos:

```
router#show crypto isakmp sa
IPv4 Crypto ISAKMP SA
dst      src      state conn-id slot      status
172.16.0.4 172.16.1.40 QM_IDLE 1004    0        ACTIVE
IPv6 Crypto ISAKMP SA
router#show crypto ipsec sa
interface: Vlan1
Crypto map tag: SDM_CMAP_1, local addr 172.16.0.4
protected vrf: (none)
local ident (addr/mask/prot/port): (0.0.0.0/0.0.0.0/0/0)
remote ident (addr/mask/prot/port):
(172.16.1.190/255.255.255.255/0/0)
current_peer 172.16.1.40 port 500
PERMIT, flags={}
#pkts encaps: 22, #pkts encrypt: 22, #pkts digest: 22
#pkts decaps: 32, #pkts decrypt: 32, #pkts verify: 32
#pkts compressed: 0, #pkts decompressed: 0
#pkts not compressed: 0, #pkts compr. failed: 0
#pkts not decompressed: 0, #pkts decompress failed: 0
#send errors 0, #recv errors 1
local crypto endpt.: 172.16.0.4, remote crypto endpt.: 172.16.1.40
path mtu 1500, ip mtu 1500
current outbound spi: 0xD35124D3(3545310419)
inbound esp sas:
spi: 0x7783DD3C(2005130556)
transform: esp-3des esp-sha-hmac ,
```

```

in use settings ={Tunnel, }
conn id: 2001, flow_id: NETGX:1, crypto map: SDM_CMAP_1
sa timing: remaining key lifetime (k/sec): (4570709/3346)
IV size: 8 bytes
replay detection support: Y
Status: ACTIVE
.....

```

Para monitorizar en tiempo real se puede utilizar el comando **debug crypto isakmp**. La siguiente sintaxis es un resumen del comando.

```

router#debug crypto isakmp
000365: Mar 26 21:00:24.056: ISAKMP (0:0): received packet from
172.16.1.40 dport 500 sport 500 Global (N) NEW SA
000366: Mar 26 21:00:24.056: ISAKMP: Created a peer struct for
172.16.1.40, peer port 500
000367: Mar 26 21:00:24.056: ISAKMP: New peer created peer =
0x47910754 peer_handle =0x80000006
000368: Mar 26 21:00:24.056: ISAKMP: Locking peer struct 0x47910754,
refcount 1 for crypto_isakmp_process_block
000369: Mar 26 21:00:24.056: ISAKMP:(0):Setting client config
settings 487F46E4
000370: Mar 26 21:00:24.056: ISAKMP:(0):(Re)Setting client xauth
list and state
000371: Mar 26 21:00:24.056: ISAKMP/xauth: initializing AAA request
! -- Beginning authentication process
000372: Mar 26 21:00:24.056: ISAKMP: local port 500, remote port 500
000373: Mar 26 21:00:24.056: ISAKMP: Find a dup sa in the avl tree
during calling isadb_insert sa = 47E78440
000374: Mar 26 21:00:24.056: ISAKMP:(0): processing SA payload.
message ID = 0
000375: Mar 26 21:00:24.056: ISAKMP:(0): processing ID payload.
message ID = 0
000376: Mar 26 21:00:24.056: ISAKMP (0:0): ID payload
.....

```

A través de RADIUS o TACACS los siguientes comandos permiten monitorizar el proceso de autenticación en tiempo real:

- **Debug aaa authentication**
- **Debug aaa authorization**
- **Debug radius**

IMPLEMENTACIÓN DEL CLIENTE VPN

CLIENTE CISCO VPN

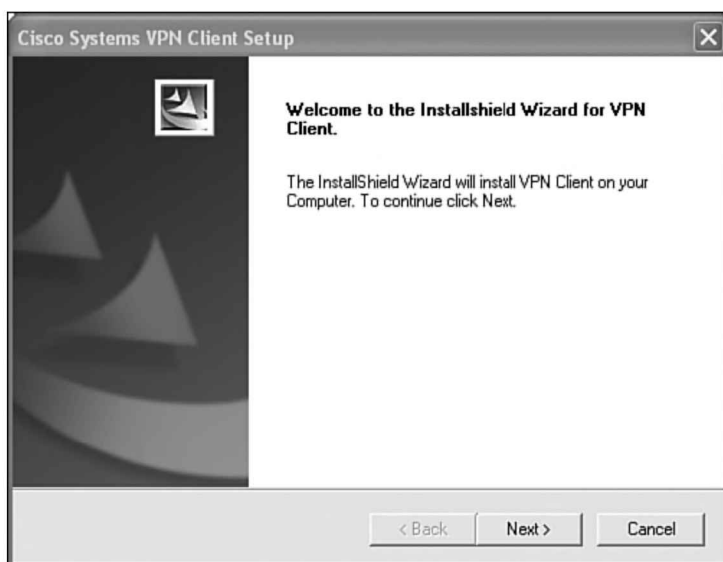
Existe un número necesario de tareas a completar para tener el cliente VPN de Cisco configurado y funcionando:

- Instalación del software.
- Creación de una nueva conexión.
- Configuración de las propiedades de autenticación en el cliente.
- Configuración de tunneling transparente.
- Habilitar y añadir servidores de respaldo.
- Configuración de una conexión a Internet vía dialup.

El cliente VPN de Cisco puede ser descargado desde la Web Cisco con el único requerimiento necesario de estar registrado, debido a que es necesario tener una cuenta CCO para acceder al software.

INSTALACIÓN DEL CLIENTE VPN

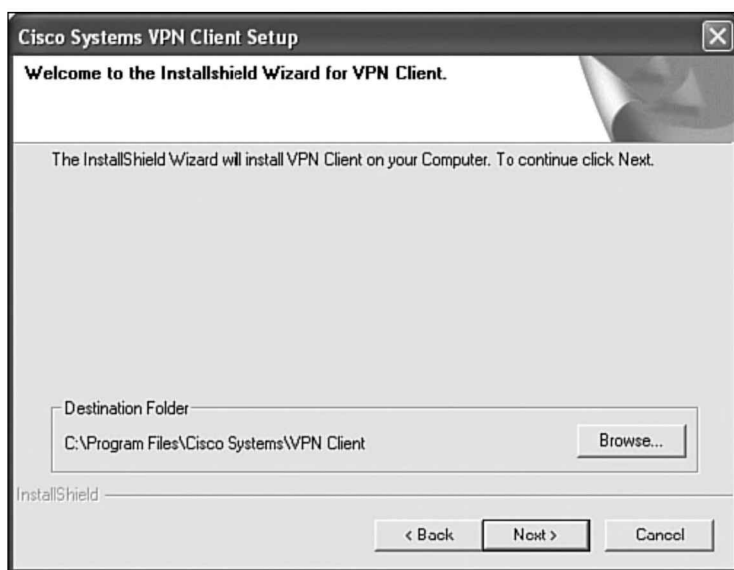
Una vez descargado el software y ejecutado el archivo para su instalación se accede a la pantalla de bienvenida, como se observa en la siguiente muestra:



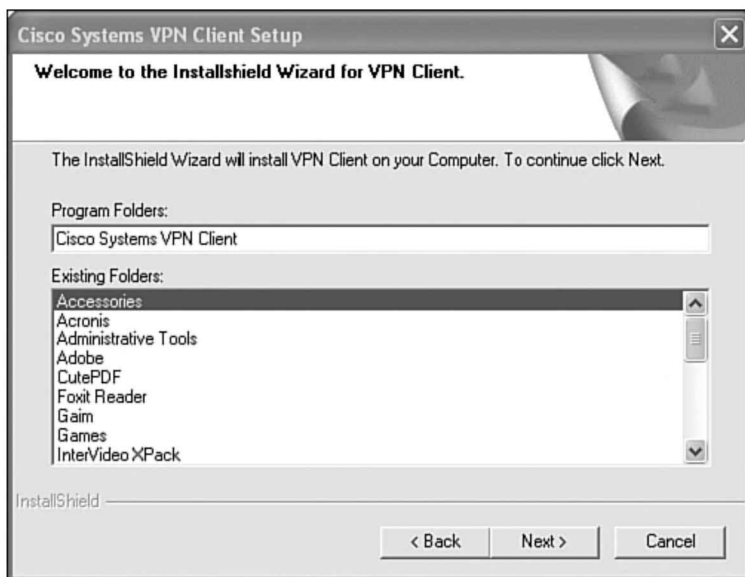
Pulsando **Next** aparecerá el acuerdo de licencia. Si hay acuerdo de condiciones pulsar **Yes**.



La siguiente ventana muestra dónde instalará el software, se puede dejar la ubicación por defecto o cambiarla.



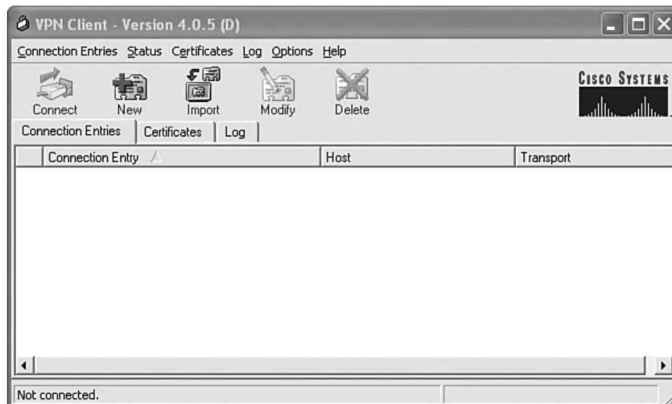
La siguiente ventana ofrece la opción de modificar cómo será mostrado el cliente en la opción **programas** de Windows. Es posible aceptar la opción por defecto o modificarla.



Durante el siguiente paso el software será instalado y una vez terminada la instalación solicitará reiniciar el ordenador para terminar con la instalación.

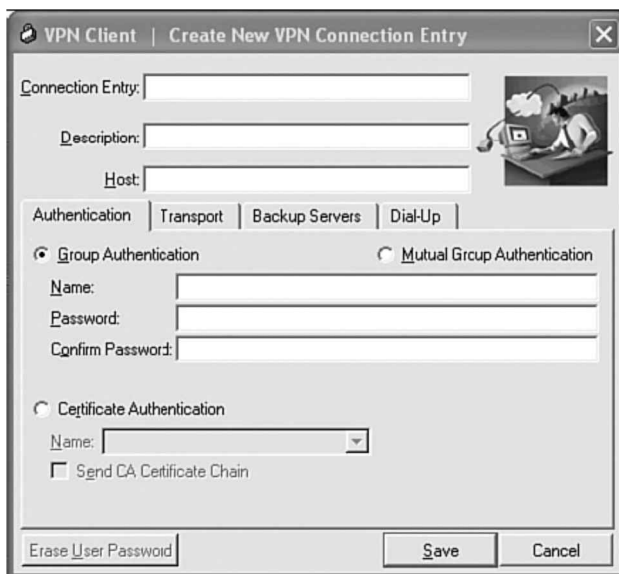
CONFIGURACIÓN DEL CLIENTE VPN

En la siguiente imagen se ilustra la interfaz del cliente VPN:



El primer paso será añadir una nueva conexión.

Pulsar el botón **New** para acceder a una pantalla como la siguiente muestra:



El campo **Connection Entry** es el nombre que llevará la conexión y tiene significado local. Aparece también otro campo llamado **Description** donde es posible dar una descripción más detallada acerca del propósito de la conexión u otra información relevante.

El campo **Host** es donde se configurará la dirección IP o nombre DNS del dispositivo VPN al que se hará la conexión.

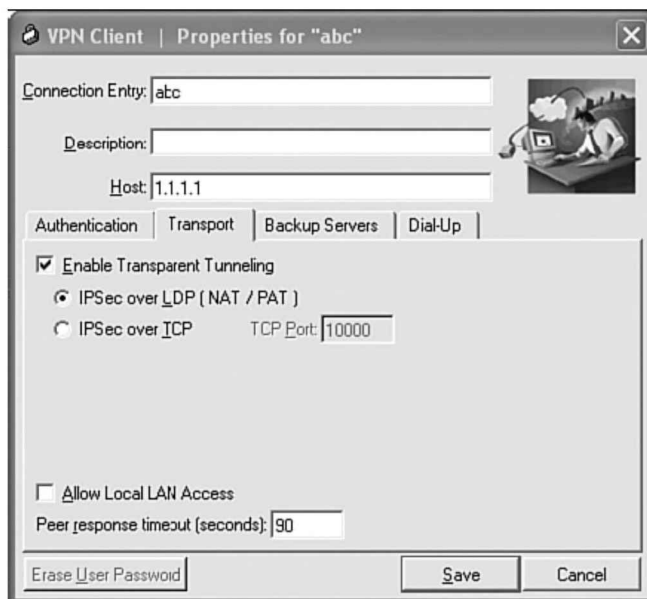
Autenticación

En la pestaña de autenticación existen tres opciones posibles:

- **Group Authentication**, es necesario introducir un nombre de usuario y una contraseña.
- **Mutual Group Authentication**, en esta opción se utiliza como autenticación un certificado digital raíz que ha de ser compatible con el gateway VPN.
- **Certificate Authentication**, permite usar un certificado digital localmente almacenado.

Transporte

La pestaña **Transport** permite la configuración de túneles transparentes, además de la posibilidad de poder seleccionar IPsec sobre UDP o sobre TCP.



El tunneling transparente permite la transferencia segura de paquetes entre el cliente VPN y el gateway VPN a través de un router que ejecuta servicios de firewall.

Normalmente dicho gateway VPN también está corriendo NAT o PAT. Los extremos IPsec esperan que la IP de destino sea globalmente alcanzable, pero hoy en día se utiliza NAT o PAT en casi cualquier red, así que el tunneling transparente permite que los extremos IPsec puedan operar en este entorno.

La configuración de tunneling transparente ha de ser común en el cliente VPN y en el gateway VPN. Tunneling transparente permite encapsular tráfico ISAKMP y ESP en datagramas TCP o UDP.

La decisión de usar IPsec sobre TCP o UDP dependerá de cómo esté configurado en el gateway VPN.

Por defecto el tunneling transparente está habilitado en el cliente, pero hay que configurarlos en el gateway VPN.

La opción **Allow Local LAN Access** proporciona acceso a recursos de red locales, como pueden ser impresoras, faxes, etc. Para poder emplearlo ha de estar configurado tanto en el cliente como en el gateway VPN.

Servidores de respaldo

La Pestaña **Backup Servers** sirve para proporcionar redundancia en caso de fallo de un servidor. Siempre es una buena idea contar con al menos otro servidor VPN de respaldo que pueda ser utilizado en caso de que el principal falle.

El uso de dichos servidores de respaldo es automático en caso de que el principal no esté disponible. El orden será descendente.

La siguiente figura muestra cómo configurarlos:



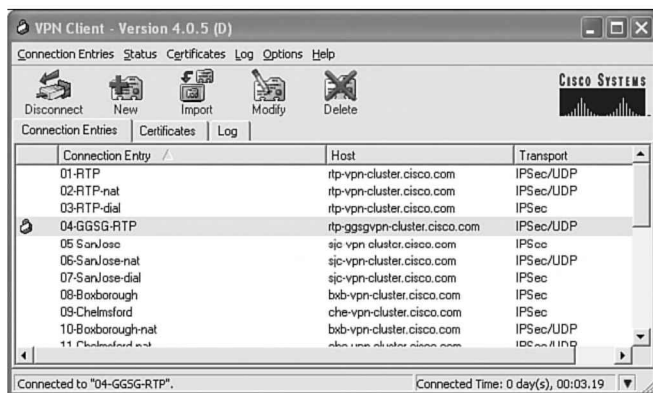
Dial-Up

En caso de que el servidor VPN sea accesible vía dial-up se configurará desde esta pestaña. **Dial-Up**

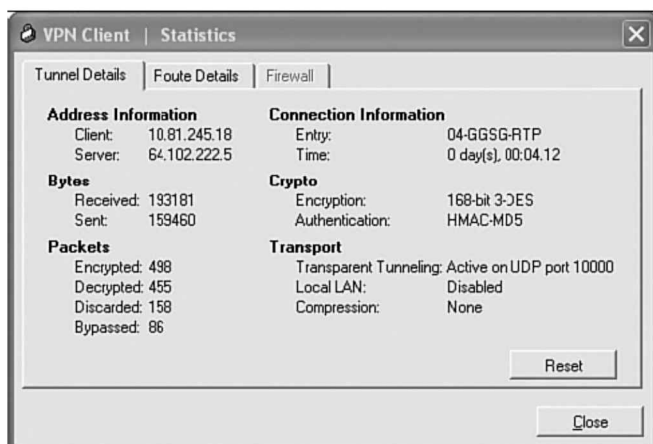


Verificación de la configuración

Desde la ventana principal del cliente VPN se muestran las conexiones creadas, para utilizar una de ellas simplemente seleccionarla haciendo doble click en ella.



Una vez establecida una conexión el menú **Status** mostrará las estadísticas:



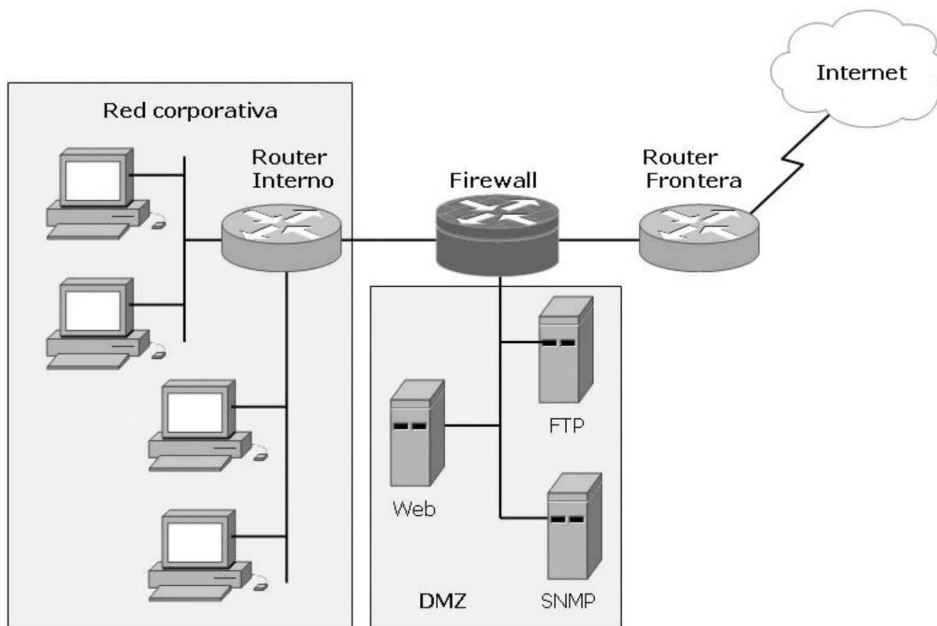
PROTECCIÓN Y SEGURIDAD DE DISPOSITIVOS

VULNERABILIDAD DE LOS ROUTERS

Como muchos otros dispositivos los routers Cisco tienen una serie de servicios habilitados por defecto. Muchos de ellos serán de utilidad y otros no, y si no existe un firewall que los proteja, estarán expuestos a diferentes tipos de ataques y vulnerabilidades.

En la figura siguiente se observa cómo la red corporativa y la **DMZ** (Demilitarized Zone) están protegidas de los ataques desde Internet mediante un firewall.

Normalmente hay más servicios accesibles en la zona desmilitarizada que en la red corporativa. La DMZ contiene servicios accesibles desde Internet por lo que las políticas de seguridad configuradas en su firewall son menos restrictivas que las configuradas para la red corporativa.



Servicios vulnerables en el router

Las siguientes tablas describen los servicios innecesarios agrupados en categorías detallando el estado en que se encuentran y cómo deshabilitarlos.

Servicios innecesarios e interfaces

Servicio	Descripción	Por defecto	Deshabilitado
Interfaces del router	Proporcionan entrada y salida de los paquetes al router. En caso de no utilizarse deberían estar deshabilitadas para prevenir que alguien las pudiera levantar conectando un cable.	Deshabilitado cuando no tienen configuración	<code>(config-if)# shutdown</code>

Servidor BOOTP	Permite al router actuar como servidor BootP. Es raramente necesitado y debería ser deshabilitado.	Habilitado	<code>(config)# no ip bootp server</code>
Cisco Discovery Protocol (CDP)	Envía información de manera periódica entre dispositivos Cisco esta información incluye por ejemplo el tipo de dispositivo, versión de IOS, direccionamiento IP, etc. Puede ser utilizado para cargar determinados ataques.	Habilitado (globalmente y en la interfaz)	<code>(config)# no cdp run</code> <code>(config-if)# no cdp enable</code>
auto-loading	Permite al router cargar una configuración mientras arranca desde un servidor.	Deshabilitado	<code>(config)# no service config</code>
Servidor FTP	Permite al router actuar como servidor FTP utilizando la memoria flash como almacenamiento de los archivos.	Deshabilitado	<code>(config)# no ftp-server enable</code>
Servidor TFTP	Permite al router actuar como servidor TFTP utilizando la memoria flash como almacenamiento de los archivos.	Deshabilitado	<code>(config)# no tftp-server file-sys:image-name</code>

Servidor NTP	Permite al router recibir fecha y hora desde un servidor NTP y a su vez actuar como servidor NTP para otros dispositivos. Debería ser configurado de manera adecuada, implementando ACL para limitar los servidores desde los que se recibe fecha y hora y también para limitar a quien enviársela. Es posible el uso de autenticación.	Deshabilitado	<code>(config)# no ntp server ip-address</code>
Packet assembler/disassembler (PAD)	Permite acceso a comandos X25 PAD en una red X25.	Habilitado	<code>(config)# no service pad</code>
Servicios TCP y UDP	Ejecuta los demonios small services.	Habilitado (inferior a 11.3) Deshabilitado (11.3 y superior)	<code>(config)# no service tcp-small-servers</code> <code>(config)# no service udp-small-servers</code>
Maintenance Operation Protocol (MOP)	Es un protocolo de mantenimiento DEC.	Habilitado (en la mayoría de interfaces Ethernet)	<code>(config-if)# no mop enabled</code>

Servicios de administración

Servicio	Descripción	Por defecto	Deshabilitado
Simple Network Management Protocol (SNMP)	Permite al router responder a peticiones SNMP así como aplicar cambios de configuración. En algunos casos será necesaria la utilización de ACL para limitar el alcance de las consultas.	Habilitado	<code>(config)# no snmp-server enable</code>
HTTP Configuración y monitorización	Permite al router ser monitorizado y configurado vía HTTP o HTTPS. SDM utiliza HTTPS, en caso de no ser utilizado será mejor que esté deshabilitado. En caso de utilización limitar acceso con ACL.	Depende del servicio	<code>(config)# no ip http server</code> <code>(config)# no ip http secure-server</code>
Domain Name Service (DNS)	Los routers Cisco usan 255.255.255.255 como dirección DNS por defecto en caso de no tener una configurada. Si se utiliza DNS lo mejor es especificar la IP y deshabilitarlo en caso de no utilizarse.	Habilitado	<code>(config)# no ip domain-lookup</code>

Mecanismos de integridad de rutas

Servicio	Descripción	Por defecto	Deshabilitado
ICMP Redirects	Hace que el router envíe un mensaje ICMP redirect cuando un paquete es reenviado vía la misma interfaz en la que es recibido. Puede ser usado por atacantes para enviar paquetes a un dispositivo “no confiable”.	Habilitado	(config)# no ip icmp redirect (config-if)# no ip redirects
IP Source Routing	Permite al emisor elegir el camino o ruta a través de la cual viajarán los paquetes en la red. Como norma general debería ser deshabilitado.	Habilitado	(config)# no ip source-route

Pruebas y escaneos

Servicio	Descripción	Por defecto	Deshabilitado
Finger service	El protocolo Finger (puerto 79) sirve para pedir una lista de usuarios a una unidad de red, dicha información incluye número de línea, nombre de la conexión, tiempo idle y localización del terminal. Es la que aparece cuando se utiliza el comando show users .	Habilitado	(config)# no service finger
ICMP unreachable notification	Notifica al emisor de subredes IP de destino inválidas.	Habilitado	(config-if)# no ip unreachable
ICMP mask reply	Envía la máscara de subred cuando ésta es pedida.	Deshabilitado	(config-if)# no ip mask-reply

IP directed broadcasts	Puede ser utilizado como ataque DOS. Se trata de tráfico unicast hasta que llega al router que contiene la subred sobre la que se va a lanzar el broadcast.	Habilitado (IOS anterior a 12.0) Deshabilitado (IOS 12.0 y superiores)	(config-if)# no ip directed-broadcast
------------------------	---	---	---

Servicios de acceso de seguridad

Servicio	Descripción	Por defecto	Habilitado/Deshabilitado
IP identification service	RFC1413. Proporciona la identidad del iniciador de la conexión TCP.	Habilitado	(config)# no ip identd.
TCP keepalives	Ayuda a limpiar conexiones TCP cuando un host remoto ha dejado de procesar paquetes TCP. Ha de ser habilitado para prevenir ciertos ataques DOS.	Deshabilitado	(config)# service tcp-keepalives-in. (config)# service tcp-keepalives-out

Servicios ARP

Servicio	Descripción	Por defecto	Deshabilitado
Gratuitous ARP	Servicio usado como medio primario en ataques de envenenamiento de ARP.	Habilitado	(config)# no ip arp gratuitous
Proxy ARP	Permite al router resolver direcciones de capa 2. Solamente es útil si el router actúa como bridge de capa 2.	Habilitado	(config)# no ip arp proxy

PROTECCIÓN CON AUTOSECURE

Autosecure es una herramienta de Cisco incorporada en la IOS 12.3 y superiores que ayuda a asegurar los routers más fácilmente. Las tareas que se pueden realizar con Autosecure son las siguientes:

- Servicios y funciones del plano de gestión. Finger, PAD, TCP y UDP small servers, encriptación de contraseñas, keepalives de TCP, CDP, BOOTP, HTTP, source routing, ARP gratuito, proxy ARP, IMCP redirects, respuestas ICMP mask, broadcast dirigido, MOP y banner.
- Servicios y funciones del plano de reenvío. CEF y ACL.
- Servicios y funciones de firewall. Firewall IOS de Cisco permite realizar funciones de inspección para determinados protocolos.
- Funciones de logging. Incluye un visor de sucesos para detectar posibles ataques.
- NTP. Asegura la configuración de este servicio.
- Acceso SSH. Es preferible el uso de SSH sobre Telnet. SSH encripta los paquetes mientras que Telnet envía contraseñas en texto plano.
- Servicios TCP Intercept. Previene ataques de tipo DoS Syn flooding.

Para habilitar Autosecure se utiliza el siguiente comando:

```
Router#auto secure [management | forwarding] [no-interact | full]
[login | ntp | ssh | firewall | tcp-intercept]
```

La opción **full** es la de por defecto. Si se selecciona **no-interact** el usuario no será preguntado por los parámetros a introducir. Es posible elegir configuraciones parciales seleccionando alguna de las opciones en lugar de **full**.

Cuando se ejecuta el comando **auto secure full** ocurren los siguientes eventos:

- Identificación de la interfaz externa o que conecta con Internet.
- Aseguración del plano de gestión.
- Creación de un banner o mensaje de seguridad.

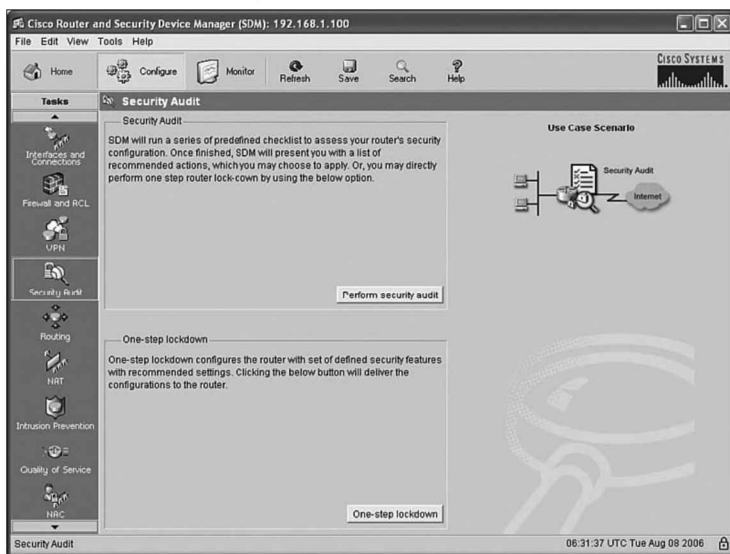
- Configuración de contraseñas, AAA y SSH.
- Aseguración de las interfaces.
- Aseguración del plano de reenvío.

Antes de ejecutar Autosecure es importante guardar una copia del contenido de la running config en caso de que sea necesario dar marcha atrás. Para IOS 12.3(8)T y superiores Autosecure crea de forma automática una copia de running config que puede ser restaurada usando el comando:

```
configure replace flash:pre_autosec.cfg
```

UTILIZACIÓN DE SDM PARA ASEGURAR EL ROUTER

Ya hemos visto en capítulos anteriores cómo manejar esta herramienta. En las siguientes muestras se verá cómo acceder a los dos asistentes disponibles para asegurar el router:

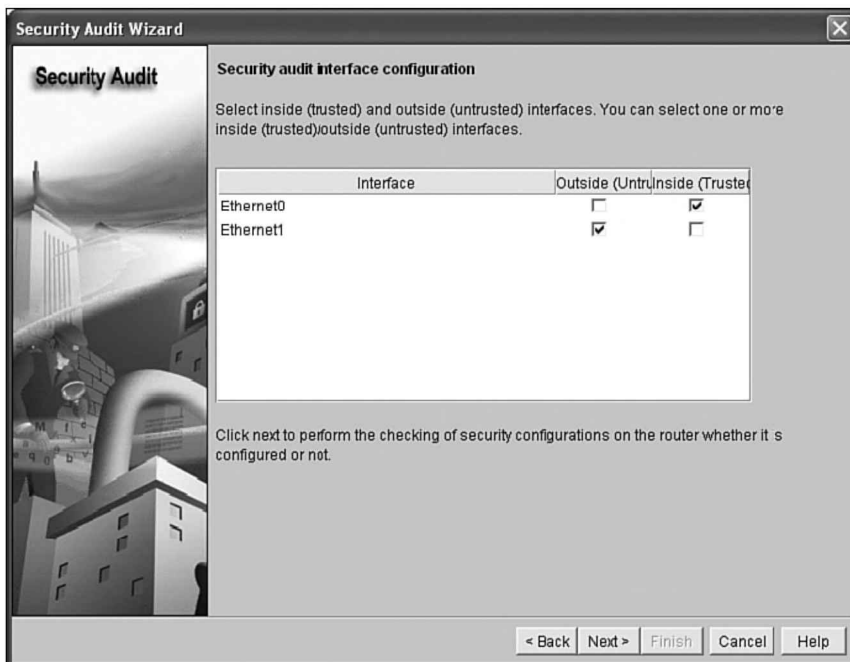


El primer asistente es llamado **Security Audit**. Se encarga de realizar un escaneo del router y reportar lo encontrado. Es posible corregir las debilidades de configuración al final del asistente. Es similar a ejecutar la opción **full** del **auto secure** en la CLI.

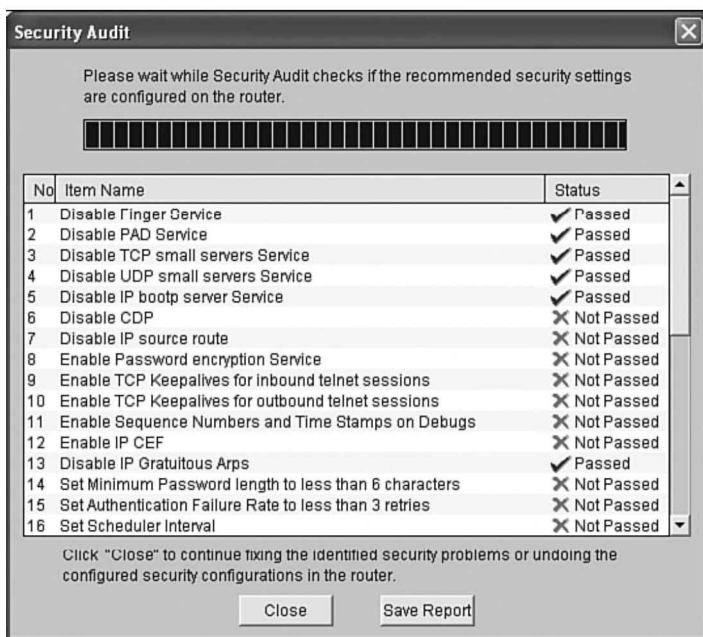
Asistente Security Audit

Para cargar el asistente se selecciona **Perform Security audit**, como se muestra en la figura anterior.

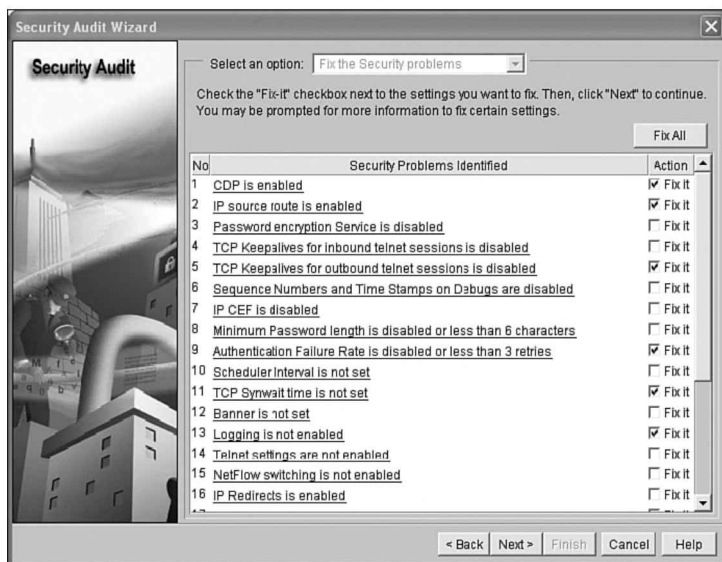
Se abre una página de bienvenida con información acerca de cómo será el procedimiento. Una vez pulsado **Next** se prosigue con la siguiente página, donde se configurarán las interfaces del router como internas (seguras) o externas (inseguras), como muestra la siguiente figura:



Se prosigue pulsando **Next**, ahora conociendo qué interfaces son internas y cuáles son externas. SDM realizará un reporte de seguridad del router, similar al que se ve en la siguiente muestra:



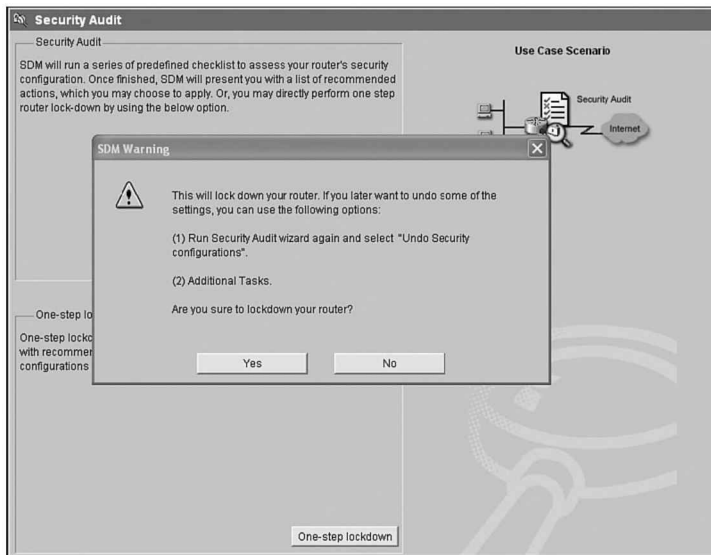
Una vez conocido el reporte se abre la posibilidad de solucionar los problemas de seguridad encontrados, como muestra la siguiente figura:



Asistente One-Step Lockdown

Este asistente está disponible desde la página **Security Audit Configure** del SDM y realiza funciones similares al **Auto secure** en CLI.

Al seleccionar esta opción se abre una ventana como la de la figura siguiente:



Hay que tener en cuenta que no hará ninguna pregunta, simplemente implementará todas las funciones correctivas mostradas en el reporte de auditoría, por lo tanto se debe tener plena seguridad de lo que se desea hacer.

ADMINISTRACIÓN SEGURA DEL ROUTER

El acceso al router puede llevarse a cabo por medio de los siguientes métodos:

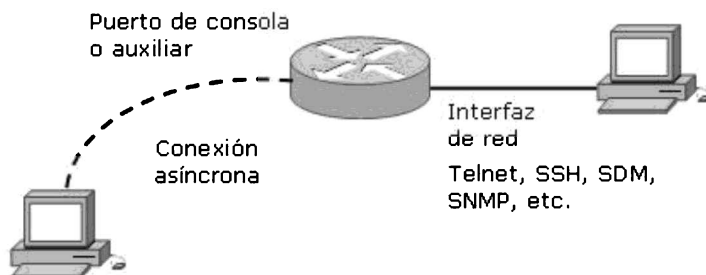
- **CLI:** usando el puerto de consola, el puerto aux o mediante una sesión lógica de Telnet o SSH.
- **Interfaz Web.** SDM es accesible vía HTTP o HTTPS.
- **SNMP.** El router puede ser configurado o “preguntado” por un servidor o estación SNMP.

Contraseñas

Algunas de las recomendaciones prácticas a tener en cuenta a la hora de establecer las contraseñas pueden ser las siguientes

- Longitud mínima. Cuantos más caracteres tenga más difícil será descubrirla.
- Mezcla de diferentes caracteres. Debería incluirse una mezcla de mayúsculas, minúsculas, números, caracteres especiales, etc. De esa manera se eleva la complejidad y las posibilidades de acertar con ella.
- No usar palabras del diccionario. De esta forma se evitan en la medida de lo posible los llamados ataques de diccionario.
- Cambiar la contraseña con frecuencia. Limitando así el uso de una contraseña que hubiera estado comprometida.

La siguiente figura muestra puntos de acceso al router que deberían estar protegidos por contraseñas.



Cuando un usuario tiene acceso físico al router podría intentar acceder utilizando una sesión asíncrona vía el puerto de consola o el puerto aux.

Desde la red el usuario puede intentar acceder vía CLI usando Telnet o SSH o también vía Web con SDM a través de HTTP o HTTPS, incluso SNMP.

Todos estos puntos de acceso pueden ser asegurados mediante el empleo adecuado de contraseñas y a su vez limitando el acceso utilizando ACL. Las contraseñas en Cisco comparten las siguientes características:

- Pueden ser de entre 1 y 25 caracteres.
- El primer carácter no puede ser un número o un espacio.
- Dentro de la contraseña, a excepción de lo citado arriba, cualquier otra combinación de caracteres es válida.
- Es aconsejable dentro de la política de seguridad aplicar una sub-política referente a contraseñas en la que se debe establecer lo siguiente:
 - Longitud mínima.
 - Consejos de cómo generar las contraseñas.
 - Frecuencia de expiración de las contraseñas.

Limitaciones en las sesiones

Incluso la contraseña más compleja siempre es susceptible a ser descubierta a través de un ataque de fuerza bruta, por ejemplo.

Por defecto, Cisco sólo permite tres intentos de acceso al router, después del tercer fallo la conexión es reseteada, pero después se podrá volver a intentar de manera sucesiva.

Muchos dispositivos de red contabilizan el número de intentos fallidos y después de que llegan al umbral deshabilitan el usuario por tiempo limitado o hasta que el administrador lo resetea.

En la siguiente muestra se observa cómo configurar un logging de fallos en la autenticación:

```
Router(config)# aaa new-model
Router(config)# aaa authentication attempts login 5
Router(config)# aaa authentication login local-policy local
!
Router(config)# security authentication failure rate threshold-rate
log
Router(config)#
```

Para que la función **security authentication** funcione es necesario implementar **AAA** (Authentication, Authorization, Accounting) cuyo proceso, en referencia al ejemplo anterior, es el siguiente:

- Habilitar AAA: **aaa new-model**
- Incrementar el número de intentos de **login** a 5
- Crear una política llamada **local-policy** que involucra al usuario local del router para autenticar a quien intenta establecer una sesión.

El comando **security authentication** tiene un sólo parámetro, **threshold rate**, que define el número de intentos de **login** fallidos durante un minuto, lo que causaría que un mensaje log fuera generado. Dicho parámetro ha de ser menor o igual a **aaa authentication attempts login**, de lo contrario el usuario sería desconectado antes de generar el log.

Desde el modo de configuración es posible utilizar el comando **login** para configurar los parámetros relativos a las sesiones y los intentos de autenticación fallidos.

```
Router(config)# aaa new-model
Router(config)# aaa authentication attempts login 5
Router(config)# aaa authentication login local-policy local
!
Router(config)# login ?
block-for Set quiet-mode active time period
delay Set delay between successive fail login
on-failure Set options for failed login attempt
on-success Set options for successful login attempt
quiet-mode Set quiet-mode options
Router(config)#
```

Como ocurre con el comando **security authentication**, para que el login funcione es necesario configurarlo en AAA. Las opciones de login son múltiples:

- Block-for
login block-for seconds attempts failed-attempts within watch-period

Permite definir tres parámetros:

- **Seconds**, número de segundos durante los cuales futuros intentos de login serán denegados (quiet period).

- **Failed-attempts**, número de intentos fallidos seguidos que hacen activar el parámetro timeout sea invocado.
 - **Watch-period**, período de tiempo durante el cual los intentos de login fallidos consecutivos tienen que ocurrir para que se invoque el “quiet period”.
-
- **Delay**. Establece un tiempo de retraso entre intentos de login fallidos. El usuario o atacante ha de esperar este período (de 1 a 10 segundos) antes de poder volver a intentar una nueva sesión. Se consigue así frenar la velocidad de cualquier ataque.
 - Las opciones **on-failure** y **on-success** habilitan opciones de login para intentos de autenticación fallidos y satisfactorios respectivamente.
 - La opción **quiet-mode** enlaza una **access-class** (como las usadas para limitar acceso vía VTY) al comando login. Los dispositivos permitidos en la access class estarán exentos de las opciones login.

Una vez configurados estos parámetros pueden verse a través del comando **show login**.

Contraseñas en el modo setup

Existen dos maneras posibles de acceder al modo setup. La primera es encender el router sin ningún tipo de configuración. La segunda es ejecutando el comando **setup** desde modo privilegiado.

En la siguiente sintaxis se muestra la parte en la que se puede configurar las contraseñas desde el modo Setup.

```
The enable secret is a password used to protect access to privileged
EXEC and
configuration modes. This password, after entered, becomes encrypted
in the configuration.
```

```
Enter enable secret: CCnP
```

```
The enable password is used when you do not specify an enable secret
password, with some older software versions, and some boot images.
```

```
Enter enable password: CCnP
```

```
% Please choose a password that is different from the enable secret
```

```
Enter enable password: CCnPtest
```

```
The virtual terminal password is used to protect access to the
router over a network interface.
```

```
Enter virtual terminal password: testCCnP
```

La primera contraseña configurable es la **enable secret** de acceso a modo privilegiado. Dicha contraseña será encriptada por el router con el algoritmo MD5.

La segunda contraseña es la **enable password**, de acceso a modo privilegiado. Esta contraseña se utilizaba antes de desarrollarse el **enable secret**. Por defecto se guardada en modo texto y en caso de existir un **enable secret**, ésta será ignorada.

El modo **Setup** no permite que las contraseñas **enable secret** y **enable password** sean iguales, al estar esta última en texto plano por defecto y ser así una vulnerabilidad.

La tercera contraseña es la de acceso a terminales virtuales. Se utiliza cuando se intenta acceder al router vía Telnet o SSH. Por defecto es almacenada en texto plano.

Con el modo **Setup** no es posible configurar las contraseñas de **aux** y **consola**.

Contraseñas por línea de comandos

Todas las contraseñas pueden ser configuradas desde la línea de comandos:

- Consola
- Aux
- VTY
- Enable password
- Enable secret

La siguiente sintaxis muestra cómo configurar varios de ellos:

```
Router(config)# enable password password
Router(config)# enable secret password
Router(config)# line { console 0 | aux 0 | vtty 0 4 }
Router(config-line)# password password
Router(config-line)# login
```

Por defecto las contraseñas de **enable**, **consola**, **aux** y **VTY** son almacenadas en texto plano mientras que la **enable secret** lo hace de manera encriptada.

Al acceder vía consola, aux y VTY se accede directamente al modo usuario, donde sólo ciertos comandos son accesibles, generalmente para ver estadísticas. Es necesario acceder a modo enable o privilegiado para realizar el resto de las funciones.

Los puertos de consola y aux son locales al router, para entrar por consola es necesario un cable de consola y para acceder por aux es necesario un módem.

El comando **login** en las líneas permite que la contraseña sea chequeada. Sin este comando la contraseña no sería utilizada. Al incluir este comando se hace obligatorio el empleo de una contraseña de acceso.

Protecciones adicionales

Utilizando contraseñas no se restringen los intentos de acceso al router debido a que cualquiera con conectividad IP puede tener acceso.

El acceso Telnet o SSH puede ser restringido mediante el empleo del comando **access-class**. Dicho comando está asociado con una ACL que permite o deniega el establecimiento de sesiones telnet o SSH. En la siguiente muestra se observa cómo asociar una **access-class** a los puertos VTY, en este caso permitiendo iniciar sesiones telnet o SSH a dos host.

```
Router(config)# access-list 10 permit 192.168.10.11
Router(config)# access-list 10 permit 192.168.4.10
Router(config)# line vty 0 4
Router(config-line)# access-class 10 in
Router(config-line)# password CCnP
Router(config-line)# login
Router(config-line)#
```

También es posible configurar temporizadores en las líneas para que las sesiones sean desconectadas en caso de inactividad. Por defecto son desconectadas a los 10 minutos de inactividad. La siguiente muestra indica los comandos para hacerlo:

```
Router(config)# line { console 0 | aux 0 | vty 0 4 }
Router(config-line)# exec-timeout minutes [ seconds ]
Router(config-line)#
```

Longitud de las contraseñas

Cuanto más largo sea el tamaño de la contraseña más seguro será. En equipos Cisco la longitud máxima es de 25 caracteres y se puede incluir cualquier carácter alfanumérico.

La política de seguridad de la red debería especificar la longitud que las contraseñas han de tener. En la siguiente sintaxis se muestra el comando para implementar una longitud mínima en las contraseñas:

```
Router(config)# security passwords min-length length
```

Una vez aplicado, el comando tendrá efecto sobre las nuevas contraseñas configuradas, no sobre las ya existentes.

Es recomendable que la longitud de la contraseña sea entorno a los 10 caracteres aunque ésta puede variar dependiendo de la complejidad de la misma.

Encriptación de contraseñas

Todas las contraseñas son guardadas inicialmente en texto plano, a excepción de la `enable secret`. Si alguien lee la configuración o gana acceso a ella podría verlas fácilmente. Cisco utiliza un algoritmo basado en la clave **Vigenere** para encriptar las contraseñas.

Al utilizar el comando **service password-encryption** todas las contraseñas quedan encriptadas, para reconocer este sistema se observa como están precedidas por el número 7. Este sistema de encriptación no es potente, simplemente se utiliza para prevenir que algún intruso que vea una muestra de un **show run** pueda reconocer las contraseñas fácilmente. Existen numerosas aplicaciones que desencriptan este sistema en cuestión de segundos.

La siguiente sintaxis muestra un antes y un después de habilitar el comando:

```
Router# show running-config  
...  
enable password ciscoCCnP  
...  
line con 0  
password CCnPtest  
login  
line vty 0 4  
password testCCnP  
login
```

```
...
Router# configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)# service password-encryption
Router(config)# end
Router# show running-config
...
enable password 7 14141B180F0B3A2A373B243A3017
...
line con 0
password 7 00071A1507541F031C351D1C5A
login
line vty 0 4
password 7 11584B56031718180723382727
login
...
Router#
```

La mejor práctica de seguridad es la utilización de un servidor RADIUS o TACACS donde almacenar las contraseñas y poder encriptarlas adecuadamente de tal forma que no sea tarea del router.

Banners

Un banner es un mensaje que aparece, según sea, antes o después de ganar acceso al router. Simplemente sirve para dar a conocer la política de seguridad y quién puede acceder al router o incluso un número de contacto del equipo que se encarga de monitorizar el router.

Tipos de banners:

- **Modt** (Message of the day), es el primer mensaje que aparece cuando se accede al router por consola, aux o VTY.
- **Exec**, es mostrado cuando un proceso exec se inicia creado.
- **Incoming**, es mostrado cuando comienza una sesión Telnet o SSH.
- **Login**, es mostrado antes de que el proceso de login (usuario y password) comience.

El banner nunca debería incluir palabras como “Bienvenido” porque podría interpretarse como una invitación a romper la seguridad del dispositivo desde un punto de vista legal.

El comando y un texto típico para un banner motd puede ser el siguiente:

```
Router(config)# banner motd #  
** ATENCIÓN ** - Cualquier acceso no autorizado está estrictamente  
prohibido y será sancionado según marca la ley vigente  
#  
Router(config)#
```

Sesiones individuales

Hasta ahora sólo se ha visto que todos los usuarios, independientemente de la tarea que puedan realizar, se identifican utilizando la misma contraseña. Esto obviamente puede mejorarse con la creación de diferentes usuarios para que cada uno de ellos pueda acceder al router empleando su propia sesión.

El siguiente es un ejemplo de usuarios y contraseñas:

```
Router(config)# username Enrique password ciscoCCnP456  
Router(config)# username Ernesto secret ciscoCCnP678  
Router(config)# line vty 0 4  
Router(config-line)# login local
```

Niveles de privilegios

Aunque ya se ha visto cómo se pueden crear diferentes usuarios, hasta ahora todos ellos comparten la misma contraseña para acceder al modo privilegiado.

Cisco IOS permite la creación de diferentes niveles de privilegios. Cuando sólo existe un nivel de privilegio todos los usuarios que tienen la contraseña pueden acceder a todas las opciones de igual forma, pero cuando hay varios niveles será necesario establecer qué comandos estarán accesibles según cada nivel.

Se pueden configurar hasta 16 niveles. El nivel 0 es el modo de usuario y el 15 es el modo privilegiado. Desde el 1 al 14 permiten personalizarse.

El siguiente comando permite la configuración de los niveles en las contraseñas de los usuarios:

```
Router(config)# privilege mode level level command  
Router(config)# enable secret level level password
```

A través del comando **privilege** se añaden comandos al nivel que se requiera. El comando **enable secret** define la contraseña necesaria para acceder a un nivel en particular. Las opciones de estos comandos son las siguientes:

- La opción **mode** selecciona una opción **exec** o de configuración que será incluida con este nivel de privilegio.
- La opción **level** es el número de nivel, entre 1 y 14.
- La opción **command** es el comando que queremos incluir en ese nivel en particular.

La siguiente sintaxis es un ejemplo:

```
Router(config)# privilege interface level 2 ip address
Router(config)# privilege interface level 2 ip
Router(config)# privilege configure level 2 interface
Router(config)# privilege exec level 2 configure terminal
Router(config)# privilege exec level 2 configure
Router(config)# privilege exec level 2 show interfaces
Router(config)# privilege exec level 2 show running-config
Router(config)# privilege exec level 2 show
Router(config)# enable secret level 2 ciscopriv2
```

Para moverse entre diferentes niveles se utiliza el siguiente comando:

```
Router>enable level
Password:
Router#
```

Finalmente se debe tener en cuenta que cada comando de IOS solamente puede utilizarse en uno de los niveles.

VISTAS BASADAS EN ROL

Con esta funcionalidad es posible crear vistas donde cada una de las cuales contendrá una lista de comandos IOS. A diferencia de los niveles de privilegio en este caso es posible que un comando exista en diferentes vistas. Es posible además ser más específico, por ejemplo, asignar una vista para una interfaz en particular y no para todas.

Desde la vista **Root** se pueden crear otras vistas y añadir los comandos.

Para configurar las vistas basadas en rol se utiliza AAA, por lo tanto como mínimo es necesario tener configurado el comando **aaa new-model**.

La siguiente sintaxis muestra cómo acceder a la vista Root:

```
Router> enable view [view-name]  
Password:
```

Con el comando **enable view** se accede a la vista **Root** y con la opción **view-name** se accede a una vista en particular.

Una vez que dentro de la vista Root se pueden crear las vistas individuales. Es posible tener un máximo de 15 vistas individuales por router. Los siguientes comandos permiten crear una vista individual:

```
Router# configure terminal  
Router(config)# parser view view-name  
Router(config-view)# password 5 view-password  
Router(config-view)# secret view-password  
Router(config-view)# commands command-type {include | exclude |  
include-exclusive} {LINE | all}  
Router(config-view)#
```

Se observa como detalle el número 5 en la configuración, esto indica que la contraseña será almacenada en formato MD5 y ésta es la única opción.

A partir de la versión de IOS 12.4 la única opción disponible es la **secret**, la cual directamente encripta en formato MD5.

Una vez configurada la contraseña la opción **commands** añade comandos IOS a la vista:

- **Command-type** selecciona la categoría del comando (exec, configure, interface, etc).
- Posteriormente se puede elegir **include** para incluir el comando o **exclude** para excluirlo. Con la opción **include-exclusive** se incluye en esta vista sin permitir que se incluya en otras.
- Se pueden seleccionar líneas individuales con la opción **LINE** o **all** para todos los comandos dentro de una categoría.

Las vistas individuales pueden ser anidadas en las llamadas super vistas. La siguiente es una muestra de los comandos respectivos:

```
Router(config)# parser view view-name superview
Router(config-view)# password 5 view-password
Router(config-view)# secret view-password
Router(config-view)# view view-name
Router(config-view)
```

Protección física del router

Si un intruso gana acceso al router de manera física y no conoce las contraseñas de consola o auxiliar, podría intentar hacer un **password recovery**, mecanismo que permite acceder al router desde el modo **ROMMON** para después cambiar el valor del registro de configuración del sistema de 0x2102 a 0x2142. Este valor del registro hace que una vez que ha cambiado, cuando el router se reinicie no cargará la configuración, pero será accesible simplemente usando el comando **show start**.

Para evitar que alguien pueda hacer un **password recovery** en el router utilizamos el siguiente comando:

```
Router(config)#no service password-recovery
```

La utilización de este comando puede resultar problemática y deben coexistir otras instancias o alternativas para recuperar la disponibilidad de la red en caso de catástrofe, como por ejemplo, un segundo router pre-configurado y listo para ser enviado si fuera necesario.

INTRODUCCIÓN A AAA

AAA es el acrónimo de Authentication, Authorization and Accounting. Cada una de las partes se detalla a continuación:

- **Authentication.** El proceso de autenticación se encarga de verificar que el usuario es quien dice ser, por ejemplo mediante el uso de un nombre de usuario y un password.
- **Authorization.** El proceso de autorización determina a qué recursos tiene acceso el usuario una vez que se ha autenticado.
- **Accounting.** El proceso de auditoría se encarga de registrar la actividad realizada por el usuario una vez que haya sido autenticado.

El proceso AAA puede resumirse en estas tres preguntas:

- *¿Quién es usted?*
- *¿Qué se le permite hacer a este usuario?*
- *¿Qué han estado haciendo los usuarios en la red?*

MODO DE ACCESOS AAA

AAA tiene dos modos de acceso, carácter y paquete, que se resumen en la siguiente tabla:

Interfaz	Modo	Descripción
AUX	Carácter	Puerto Auxiliar DTE
Consola	Carácter	Puerto de Consola
TTY	Carácter	Puerto Asíncrono
VTY	Carácter	Terminales Virtuales
PPP	Paquete	Interfaces PPP, serial o ISDN
Arap	Paquete	AppleTalk Remote Access (ARA)
NASI	Paquete	NetWare Access Server Interface o interfaz serie

PROTOCOLOS TACACS+ Y RADIUS

Ambos protocolos se encargan de proporcionar servicios AAA, pero existen diferencias entre ellos. RADIUS está definido en la RFC 2865 y TACACS+ en la RFC 1492.

RADIUS utiliza UDP mientras que TACACS+ utiliza TCP, lo que conlleva a una serie de diferencias en el comportamiento de ambos protocolos.

- TCP proporciona dos mecanismos para saber que el servidor ha fallado: uno a través de las banderas RST y el otro a través de los keepalives. En el caso de UDP son las aplicaciones las que deben realizar estas funciones.
- TCP escala mejor que UDP en grandes redes, especialmente si la red tiende a estar congestionada.

- TCP permite múltiples conexiones simultáneas a múltiples servidores enviando automáticamente sólo a aquellos que estén activos. UDP necesitaría programación extra en las aplicaciones.

TACACS+ separa completamente los procesos de autenticación y autorización y soporta más protocolos que RADIUS, mientras que RADIUS los unifica.

Los siguientes protocolos no son soportados por RADIUS:

- AppleTalk Remote Access (ARA) protocol
- NetBIOS Frames Protocol Control protocol
- Novell Asynchronous Services Interface (NASI)
- X.25 PAD connection

RADIUS no permite especificar qué comandos puede utilizar el usuario después de iniciar una sesión en el router, simplemente permite o deniega el acceso al equipo.

TACACS+ tiene dos métodos de autorizar el uso de comandos en el router:

- Especificando en el servidor TACACS+ los comandos que se permiten usar a un determinado usuario o grupo.
- Confiando en los niveles de privilegio. Se lanza una consulta al servidor TACACS+ para ver si el usuario o grupo puede usar un determinado comando en un determinado nivel de privilegio.

CONFIGURACIÓN DE AAA CON CLI

Configuración de RADIUS

En la siguiente sintaxis se muestra una configuración de AAA utilizando RADIUS:

```
aaa new-model
radius-server host 10.10.1.5
radius-server key TheRADIUSServerKey
username root password MySecretPassword
aaa authentication ppp mydiallist radius local
aaa authorization network radius local
aaa accounting network mynetwork start-stop group radius
```

Configuración de TACACS+

En la siguiente sintaxis muestra una configuración de AAA utilizando TACACS+:

```
aaa new-model
tacacs-server host 10.10.1.5
tacacs-server key TheTacacsServerKey
username root password MySecretPassword
aaa authentication ppp mydiallist tacacs+ local
aaa authorization commands 15 tacacs+ if-authenticated none
aaa accounting network start-stop tacacs+
```

Configuración de AAA

- **aaa new-model**, sirve para habilitar AAA en el router. Si se utiliza la forma **no** delante quedará deshabilitado.
- **radius-server host**, se utiliza para indicar el servidor RADIUS. El comando tiene varias opciones, la sintaxis completa es la siguiente:

```
radius-server host {hostname | ip-address} [auth-port port-number] [acct-port port-number] [timeout seconds] [retransmit retries] [key string] [alias {hostname | ip-address}]
```

La siguiente tabla describe los parámetros:

Parámetro	Descripción
hostname	Especifica un nombre para el servidor RADIUS.
ip-address	Especifica una dirección IP para el servidor RADIUS.
auth-port	Especifica el puerto UDP para las solicitudes de autenticación.
port-number	Número de puerto para las autenticaciones (0 no se utiliza; por defecto 1645).
acct-port	Especifica el puerto UDP para las solicitudes de auditoría.
port-number	Número de puerto para las auditorías (0 no se utiliza; por defecto 1646).
timeout	Especifica el valor en segundos que el router espera por la respuesta del servidor RADIUS antes de reenviar una petición.
seconds	Especifica el valor del timeout.
retransmit	Especifica el número de veces que una petición al servidor RADIUS es retransmitida.
retries	Especifica el valor de la retransmisión.
key	Especifica que una clave para autenticar y encriptar será utilizada entre el router y el servidor RADIUS.
string	Especifica el valor de la clave.
alias	Especifica hasta 8 alias que se pueden dar a un servidor RADIUS.

- **tacacs-server host**, se utiliza para indicar el servidor RADIUS. El comando tiene varias opciones, vemos a continuación la sintaxis completa: